

Universidad Nacional de San Cristóbal de Huamanga
Facultad de Ingeniería de Minas, Geología y Civil — Escuela Profesional de Ingeniería de Sistemas
IS-487 — Gestión de Riesgos y Seguridad de TI

CAPÍTULO 1

Fundamentos de la Seguridad de la Información

Principios, evolución histórica y panorama de amenazas en 2026

Resumen

Este capítulo presenta una introducción integral a la seguridad de la información, entendida como una disciplina que trasciende lo meramente tecnológico para constituirse en un componente estratégico de la sostenibilidad organizacional. Se parte de una distinción conceptual entre dato, información y conocimiento, para luego desarrollar la definición normativa establecida por la ISO/IEC 27000:2018 y delimitar las fronteras entre seguridad de la información, ciberseguridad y seguridad informática. Posteriormente, se traza la evolución histórica de la disciplina desde los controles físicos de los mainframes de los años 60 hasta los retos contemporáneos asociados a la inteligencia artificial y la criptografía post-cuántica. El núcleo conceptual lo constituye el análisis detallado de la tríada CIA —Confidencialidad, Integridad y Disponibilidad—, complementada con las propiedades adicionales de autenticación y no repudio. Finalmente, se examina el panorama de amenazas para el año 2026, con especial atención a vectores devastadores como el ransomware con extorsión múltiple, los ataques a la cadena de suministro y las amenazas potenciadas por inteligencia artificial, cerrando con una propuesta arquitectónica de defensa basada en el ecosistema Personas-Procesos-Tecnología (PPT).

Palabras clave: seguridad de la información, tríada CIA, ciberseguridad, ISO/IEC 27001, gestión de riesgos, ransomware, ingeniería social, inteligencia artificial.

1.1. Introducción: el escenario del desastre

Imagine que, al iniciar sus labores académicas mañana, descubriera que la totalidad de los sistemas de información de su institución universitaria ha sido comprometida. Las notas del semestre, los expedientes de matrícula, los proyectos de investigación en curso, los registros

administrativos —absolutamente todo— se encuentran cifrados por un atacante que exige el pago de un rescate en criptomonedas para devolver el acceso. ¿Cuánto tiempo tomaría recuperar la operatividad? ¿Existen respaldos confiables? ¿Quién sería el responsable institucional?

Este escenario, lejos de ser una hipótesis especulativa, constituye una realidad documentada de manera reiterada en la última década. En mayo de 2017, el ransomware WannaCry paralizó durante un solo día los servicios del National Health Service del Reino Unido, las plantas de manufactura de Renault en Francia y los sistemas de telecomunicaciones de Telefónica en España, afectando aproximadamente a 200,000 equipos distribuidos en 150 países (Mohurle & Patil, 2017). En 2021, el ataque contra Colonial Pipeline obligó a suspender el suministro de combustible en la costa este de los Estados Unidos, demostrando que un incidente digital puede generar consecuencias físicas inmediatas sobre infraestructura crítica (CISA, 2021).

La conclusión es inequívoca: la seguridad de la información ha dejado de ser un problema confinado al área de tecnologías de información para convertirse en una cuestión de supervivencia organizacional. El presente capítulo tiene por objeto establecer las bases conceptuales que permitirán abordar el resto del curso, respondiendo de manera ordenada a tres preguntas fundamentales: ¿qué es realmente la seguridad de la información?, ¿sobre qué principios se construye? y ¿a qué amenazas se enfrenta en el contexto actual?

1.2. La cadena de valor: del dato al conocimiento

Antes de abordar la protección de la información, conviene precisar qué se entiende por ella. Para ello resulta útil la jerarquía clásica propuesta por Ackoff (1989), que distingue tres niveles ascendentes: dato, información y conocimiento.

El **dato** constituye el nivel más básico: un registro crudo, descontextualizado, carente de significado por sí mismo. El número 37.5, aislado, no comunica nada útil; podría ser una temperatura, una calificación, un precio o una coordenada geográfica. Cuando ese dato se contextualiza y se le otorga propósito, se transforma en **información**: el enunciado «la temperatura corporal del paciente es 37.5 °C» permite ya la interpretación. Finalmente, cuando un profesional aplica su experiencia para procesar esa información y derivar una conclusión accionable —«el paciente presenta fiebre leve y requiere observación»—, se ha alcanzado el nivel del

conocimiento, entendido como información procesada que habilita la toma de decisiones (Rowley, 2007).

Esta distinción no es meramente académica. Al hablar de seguridad de la información no se está protegiendo únicamente cadenas de bits y bytes almacenados en discos duros, sino el significado, el valor y, en última instancia, la capacidad organizacional para tomar decisiones informadas. En la economía contemporánea, la información se ha consolidado como el activo más valioso de cualquier organización, superando con frecuencia en valor a sus activos tangibles. Un edificio destruido puede reconstruirse; la información estratégica filtrada, las investigaciones comprometidas o los datos de clientes expuestos pueden, en cambio, comprometer la viabilidad institucional misma.

1.3. La naturaleza de la seguridad de la información

La definición de referencia internacionalmente aceptada se encuentra en la norma ISO/IEC 27000:2018, que constituye el vocabulario estándar para la familia de normas de gestión de seguridad de la información. Esta norma define la seguridad de la información en los siguientes términos:

La preservación de la confidencialidad, integridad y disponibilidad de la información; adicionalmente, pueden estar involucradas otras propiedades, tales como autenticidad, responsabilidad, no repudio y fiabilidad.

(ISO/IEC, 2018, cláusula 3.28)

Cada elemento de esta definición merece análisis detenido. El término preservación es deliberado: no se habla de creación ni de implementación, sino de un estado que debe mantenerse de manera continua. La seguridad no es, por tanto, un producto que se adquiere e instala una sola vez, sino un proceso permanente que requiere evaluación, ajuste y mejora constantes, análogo al cuidado de la salud humana (Schneier, 2000). Por su parte, la enumeración de confidencialidad, integridad y disponibilidad establece los tres pilares fundamentales —la denominada tríada CIA— sobre los cuales se diseña la totalidad de los controles de seguridad. El adverbio adicionalmente introduce, finalmente, propiedades complementarias cuya relevancia ha crecido en las últimas décadas a medida que la digitalización de las transacciones ha hecho indispensables las garantías de autenticidad y no repudio.

De esta definición se derivan cuatro implicaciones fundamentales que conviene retener. En primer lugar, lo que se protege es la información, no únicamente las computadoras; el equipamiento tecnológico es un medio, no el fin último. En segundo lugar, la protección aplica a la información en cualquier formato: digital, impreso o verbal. Un expediente clínico abandonado sobre una mesa constituye una violación de seguridad tanto como una intrusión informática. En tercer lugar, se trata de un proceso continuo, no de un producto. Y, en cuarto lugar, la seguridad involucra de manera indisoluble a personas, procesos y tecnología; ninguno de estos tres componentes por sí solo es suficiente.

1.4. Delimitación del alcance: seguridad de la información, ciberseguridad y seguridad informática

Una confusión frecuente, incluso entre profesionales, consiste en emplear como sinónimos los términos seguridad de la información, ciberseguridad y seguridad informática. Aunque relacionados, designan dominios de protección de distinta amplitud, organizados en una relación de inclusión jerárquica (von Solms & van Niekerk, 2013).

La **seguridad de la información** constituye el concepto más amplio. Comprende la protección de la información en cualquier formato —digital, impreso o verbal—, e incluye dimensiones como las políticas organizacionales, la cultura de seguridad, la clasificación documental y la gestión integral de riesgos. La divulgación inadvertida de información confidencial durante una conversación social en un café puede ser, bajo este enfoque, tan grave como una intrusión técnica sofisticada.

La **ciberseguridad**, a su vez, constituye un subconjunto de la seguridad de la información, restringido al ámbito del ciberespacio. Se ocupa específicamente de la protección de sistemas, redes y datos frente a amenazas originadas o materializadas en el entorno digital interconectado (NIST, 2020). Es el dominio que con mayor frecuencia capta la atención mediática y el imaginario popular.

Finalmente, la **seguridad informática** representa el nivel más técnico y operativo, centrado en la protección de la infraestructura tecnológica concreta: hardware, software y redes. Configurar un firewall, instalar antivirus, cifrar discos o gestionar el control de acceso a servidores son actividades propias de este dominio.

La relación entre estos tres conceptos puede sintetizarse como sigue: la seguridad de la información contiene a la ciberseguridad, y la ciberseguridad contiene a la seguridad informática. Para ilustrar la diferencia con un ejemplo cotidiano: una organización puede contar con los mejores firewalls del mercado, configurados rigurosamente —exhibiendo así una seguridad informática excelente— y, sin embargo, padecer una pésima seguridad de la información si sus empleados anotan las contraseñas en notas adhesivas pegadas a los monitores. El curso que aquí se introduce adoptará la perspectiva más amplia, integrando los tres niveles bajo la lógica de la gestión integral del riesgo.

1.5. Evolución histórica: de las cerraduras a la inteligencia artificial

La comprensión del estado actual de la disciplina requiere situarla en perspectiva histórica. La seguridad de la información ha atravesado al menos seis grandes etapas en las últimas seis décadas, cada una caracterizada por amenazas, tecnologías y paradigmas defensivos distintos.

1.5.1. Era física (décadas de 1960 y 1970)

Durante este período inicial, la seguridad era esencialmente un problema físico. Los mainframes, equipos de gran tamaño y costo, se alojaban en salas controladas con acceso restringido por cerraduras y personal de vigilancia. El control de acceso a la información se confundía con el control de acceso al edificio. La superficie de ataque era reducida porque las máquinas eran escasas, especializadas y operadas por personal técnico especializado.

1.5.2. Era del software (década de 1980)

La aparición y proliferación de la computadora personal, junto con las primeras redes locales, modificó radicalmente el escenario. En 1986 emergió Brain, considerado el primer virus para PC, y en 1988 el Morris Worm marcó el inicio de los gusanos de Internet (Spafford, 1989). Surgieron entonces las primeras contraseñas como mecanismo de autenticación y los primeros productos antivirus comerciales. La seguridad comenzó a ser concebida como una cuestión de software, no únicamente de instalaciones.

1.5.3. Era de las redes y el cumplimiento (década de 1990 y comienzos de 2000)

La masificación de Internet trajo consigo amenazas globales. Aparecieron los firewalls como mecanismo de separación entre redes confiables y no confiables, el protocolo SSL/TLS para cifrar las comunicaciones web y las primeras políticas formales de seguridad corporativa. En 2005, la publicación de la norma ISO/IEC 27001 formalizó la gestión sistemática de la seguridad bajo un enfoque de sistema de gestión, y regulaciones como la Sarbanes-Oxley Act en los Estados Unidos convirtieron el cumplimiento normativo en una obligación legal (ISO/IEC, 2022).

1.5.4. Era de la nube y las amenazas persistentes (década de 2010)

La adopción masiva del cómputo en la nube y la sofisticación creciente de los atacantes dieron lugar a las Amenazas Persistentes Avanzadas (APT, por sus siglas en inglés), conducidas por grupos organizados con frecuencia patrocinados por Estados (Mandiant, 2013). Surgieron los sistemas SIEM (Security Information and Event Management) para la correlación centralizada de eventos, y se formuló el modelo Zero Trust, basado en el principio de no asumir confianza por defecto en ningún componente, interno o externo (Kindervag, 2010).

1.5.5. Era de la inteligencia artificial y la criptografía post-cuántica (década de 2020)

La etapa actual se caracteriza por la incorporación de la inteligencia artificial tanto como vector de ataque cuanto como herramienta defensiva, y por la preparación anticipada frente a la amenaza que representa la computación cuántica para los algoritmos criptográficos vigentes. En 2024, el National Institute of Standards and Technology (NIST) publicó los primeros estándares finalizados de criptografía post-cuántica, iniciando la transición global hacia esquemas resistentes a Q-Day (NIST, 2024).

1.6. La fundación arquitectónica: la tríada CIA

Si la seguridad de la información tuviera un único modelo conceptual de referencia, ese sería la tríada CIA, acrónimo derivado de los términos en inglés Confidentiality, Integrity, Availability —Confidencialidad, Integridad y Disponibilidad. Estos tres principios constituyen, desde hace varias décadas, el fundamento sobre el que se diseña la totalidad de los controles de

seguridad existentes, desde un simple candado hasta los sistemas de defensa nacional más complejos.

1.6.1. Confidencialidad

La norma ISO/IEC 27000:2018 define la confidencialidad como «la propiedad de que la información no esté disponible o sea divulgada a individuos, entidades o procesos no autorizados» (ISO/IEC, 2018, cláusula 3.10). En términos prácticos, garantizar la confidencialidad implica asegurar que únicamente quienes tienen autorización explícita puedan acceder a un determinado activo informacional.

Los mecanismos clásicos para preservar la confidencialidad incluyen el cifrado de datos —tanto en reposo como en tránsito—, el control de acceso basado en roles (RBAC, Role-Based Access Control), la autenticación multifactor (MFA) y la aplicación del principio del menor privilegio. Algoritmos como AES (Advanced Encryption Standard) o protocolos como TLS 1.3 constituyen el estado del arte tecnológico para esta función (Rescorla, 2018). Las amenazas características contra la confidencialidad incluyen el phishing, las fugas de información, la interceptación de comunicaciones en redes inalámbricas no protegidas y técnicas de bajo perfil como el shoulder surfing.

Un caso paradigmático de fallo de confidencialidad es la brecha de Equifax de 2017. Una vulnerabilidad sin parchar en el framework Apache Struts permitió a los atacantes acceder a información personal sensible de aproximadamente 147 millones de personas, con un costo total estimado de 1,400 millones de dólares y consecuencias regulatorias que aún persisten (U.S. GAO, 2018).

1.6.2. Integridad

La integridad es definida por la norma ISO/IEC 27000:2018 como «la propiedad de exactitud y completitud» (ISO/IEC, 2018, cláusula 3.36). Aplicada a la información, esta propiedad exige que los datos permanezcan consistentes, exactos y confiables a lo largo de todo su ciclo de vida, sin alteraciones no autorizadas.

Los mecanismos técnicos para garantizar la integridad incluyen las funciones hash criptográficas —como SHA-256 o SHA-3—, las firmas digitales basadas en infraestructura de

clave pública (PKI), los sistemas de control de versiones y los registros de auditoría inmutables. Las amenazas características contra la integridad comprenden la alteración no autorizada de registros, la inyección de código malicioso y los ataques de manipulación en tránsito.

El incidente de SolarWinds, descubierto en diciembre de 2020, ilustra de manera dramática las consecuencias de un compromiso de integridad. Atacantes lograron inyectar código malicioso en las actualizaciones legítimas de la plataforma Orion, distribuyendo así una puerta trasera a aproximadamente 18,000 organizaciones, entre ellas múltiples agencias del gobierno federal de los Estados Unidos (CISA, 2021).

1.6.3. Disponibilidad

La disponibilidad se define en la norma ISO/IEC 27000:2018 como «la propiedad de ser accesible y utilizable a petición de una entidad autorizada» (ISO/IEC, 2018, cláusula 3.7). La información perfectamente confidencial e íntegra carece de utilidad si quienes están autorizados a usarla no pueden acceder a ella cuando la necesitan.

Los mecanismos para preservar la disponibilidad incluyen la redundancia de componentes (sistemas RAID, balanceadores de carga, clústeres de alta disponibilidad), las estrategias de respaldo —siendo la regla 3-2-1 una práctica recomendada de amplia adopción—, los planes de continuidad del negocio y los servicios de mitigación de ataques de denegación distribuida (DDoS).

El caso ya mencionado de WannaCry, en mayo de 2017, constituye el ejemplo arquetípico de un ataque contra la disponibilidad: hospitales del National Health Service del Reino Unido se vieron forzados a cancelar cirugías y desviar ambulancias porque los profesionales médicos no podían acceder a las historias clínicas cifradas por el ransomware (Mohurle & Patil, 2017).

1.6.4. El equilibrio como desafío arquitectónico

El reto fundamental en el diseño de controles de seguridad no consiste en maximizar individualmente cada uno de los tres pilares, sino en lograr un equilibrio adecuado entre ellos. Reforzar excesivamente uno suele debilitar otros: capas adicionales de cifrado mejoran la confidencialidad pero pueden degradar la disponibilidad por incremento de latencia; mecanismos extensivos de respaldo elevan la disponibilidad pero pueden multiplicar las superficies expuestas,

afectando la confidencialidad. La gestión de la seguridad es, en este sentido, un ejercicio permanente de ponderación entre objetivos parcialmente contrapuestos.

1.6.5. Matriz diagnóstica de la tríada CIA

La siguiente tabla sintetiza, para cada pilar, los mecanismos de defensa habituales, las amenazas más relevantes y un caso histórico ilustrativo.

Dimensión	Confidencialidad	Integridad	Disponibilidad
Mecanismos de defensa	Cifrado (AES, TLS 1.3); control de acceso (RBAC); autenticación multifactor (MFA).	Funciones hash (SHA-256); firmas digitales; control de versiones (Git).	Redundancia (RAID, balanceo); respaldos (regla 3-2-1); protección anti-DDoS.
Principales amenazas	Phishing; fugas de datos; interceptación WiFi; shoulder surfing.	Alteración no autorizada de registros; inyección de código malicioso.	Ataques de denegación de servicio (DDoS); ransomware.
Caso histórico	Equifax (2017). Vulnerabilidad en Apache Struts expuso datos de 147 millones de personas; costo aproximado: USD 1,400 millones.	SolarWinds (2020). Código malicioso inyectado en actualizaciones legítimas afectó a 18,000 organizaciones.	WannaCry (2017). 200,000 equipos infectados en 150 países; hospitales paralizados sin acceso a historias clínicas.

Tabla 1. Matriz diagnóstica de la tríada CIA. Elaboración propia con base en ISO/IEC (2018), CISA (2021) y U.S. GAO (2018).

1.7. Más allá de la tríada: autenticación y no repudio

Aunque la tríada CIA continúa siendo el marco conceptual de referencia, la creciente complejidad de las transacciones digitales ha hecho indispensable incorporar dos propiedades complementarias: la autenticación y el no repudio. Ambas se encuentran explícitamente reconocidas en la norma ISO/IEC 27000:2018 entre las «otras propiedades» que pueden estar involucradas en la preservación de la seguridad.

1.7.1. Autenticación multifactor

La autenticación responde a una pregunta esencial: ¿es usted quien afirma ser? Durante décadas, esta verificación se basó exclusivamente en algo que el usuario sabía: una contraseña. Sin embargo, la masificación de filtraciones de credenciales y el desarrollo de técnicas de ingeniería social han evidenciado la insuficiencia de este único factor. Investigaciones recientes confirman

que las brechas que involucran credenciales robadas o comprometidas tardan en promedio 292 días en ser identificadas y contenidas, el plazo más largo entre todos los vectores de ataque estudiados (IBM Security, 2024).

El paradigma actual exige la autenticación multifactor (MFA), que combina al menos dos de los siguientes tres tipos de factores: (a) algo que el usuario *sabe*, como una contraseña o un PIN; (b) algo que el usuario *tiene*, como un dispositivo móvil que recibe un código temporal o un token físico; y (c) algo que el usuario *es*, esto es, un factor biométrico —huella dactilar, reconocimiento facial o de iris. La combinación de factores eleva drásticamente la dificultad para un atacante, pues comprometer una credencial deja de ser suficiente para obtener acceso (NIST, 2020).

1.7.2. No repudio

El no repudio garantiza que el autor de una acción no pueda negar posteriormente haberla realizado. En el contexto digital, donde las transacciones carecen de los soportes tradicionales —firma manuscrita, presencia física, sellos notariales—, esta propiedad asume una relevancia crítica. Los mecanismos técnicos que la sustentan incluyen las firmas digitales basadas en infraestructura de clave pública (PKI) y los registros de auditoría inmutables, frecuentemente implementados mediante tecnologías de cadenas de bloques o sistemas de almacenamiento WORM (Write Once, Read Many).

La evidencia criptográfica resultante posee, en muchas jurisdicciones, valor legal pleno, equivalente al de una firma manuscrita en el papel. En el Perú, la Ley N.º 27269 de Firmas y Certificados Digitales y su reglamento establecen el marco jurídico para esta equivalencia funcional.

1.8. Telemetría de amenazas: el panorama 2026

La magnitud y la dinámica del cibercrimen contemporáneo desafían cualquier descripción estática. A continuación, se presentan cuatro indicadores que permiten dimensionar el problema en términos cuantitativos.

Costo global proyectado. Según las proyecciones de Cybersecurity Ventures, el costo global del cibercrimen alcanzó los 10.5 billones de dólares anuales en 2025 y se estima que llegará a 12.2 billones en 2031. De considerarse al cibercrimen como una economía nacional, ocuparía el

tercer lugar mundial, después de los Estados Unidos y China (Morgan, 2020; Cybersecurity Ventures, 2025).

Costo promedio por brecha. El reporte anual «Cost of a Data Breach» publicado por IBM Security situó el costo promedio global por brecha de datos en 4.88 millones de dólares para 2024, lo que representa un incremento del 10 % respecto al año anterior, el mayor salto anual desde la pandemia (IBM Security, 2024).

Tiempo promedio de detección y contención. El mismo reporte de IBM documenta que las organizaciones tardaron, en promedio, 258 días en identificar y contener una brecha de seguridad durante 2024, cifra que descendió desde los 277 días registrados el año previo y que constituye el mínimo de los últimos siete años (IBM Security, 2024). Aun así, supone más de ocho meses de exposición activa, durante los cuales el atacante puede consolidar su presencia y maximizar el daño.

Brecha de talento. El World Economic Forum estimó en 2024 una brecha global de aproximadamente 4.8 millones de puestos de trabajo no cubiertos en ciberseguridad, situación que configura un mercado laboral con desempleo prácticamente nulo en la disciplina (WEF, 2024). Las proyecciones del U.S. Bureau of Labor Statistics anticipan un crecimiento del 35 % en empleos del sector entre 2021 y 2031, muy por encima del promedio de otras ocupaciones.

1.9. El factor multiplicador: amenazas potenciadas por inteligencia artificial

La irrupción de los modelos de lenguaje de gran escala y de las técnicas de aprendizaje profundo aplicadas a la generación de contenido sintético ha alterado cualitativamente el panorama de amenazas. La inteligencia artificial actúa hoy como un factor multiplicador que amplifica vectores conocidos y habilita otros enteramente nuevos.

Phishing potenciado por modelos de lenguaje. Los atacantes utilizan modelos de lenguaje de gran escala (LLM) para generar correos electrónicos altamente personalizados, gramaticalmente impecables y adaptados al perfil profesional de cada víctima, frecuentemente construido a partir de información pública obtenida de redes profesionales. Este tipo de mensajes

resulta indetectable por los heurísticos tradicionales basados en errores ortográficos o expresiones genéricas.

Deepfakes y fraude del CEO. La clonación en tiempo real de voz e imagen ha viabilizado fraudes de gran magnitud. El caso de Hong Kong en febrero de 2024 es ilustrativo: un empleado del área financiera de una multinacional transfirió 25 millones de dólares tras participar en una videoconferencia en la que todos los demás asistentes —incluido el supuesto director financiero— eran deepfakes generados en tiempo real (Chen & Magramo, 2024).

Malware mutante. El código malicioso asistido por inteligencia artificial puede reescribir su propia estructura para evadir la detección basada en firmas, dificultando la identificación por parte de las soluciones antivirus tradicionales y exigiendo el desplazamiento hacia esquemas de detección basados en comportamiento.

Envenenamiento de datos. Una clase emergente de ataques apunta directamente a los datos de entrenamiento de los modelos de inteligencia artificial defensivos, corrompiéndolos de manera silenciosa para que el modelo termine aprobando como legítimas operaciones fraudulentas o pasando por alto patrones de ataque (Goldblum et al., 2023).

1.10. Vectores devastadores: ransomware y cadena de suministro

1.10.1. La evolución del ransomware: del cifrado a la extorsión múltiple

El ransomware ha experimentado una evolución que puede caracterizarse en tres etapas. La extorsión simple, predominante hasta aproximadamente 2018, consistía en cifrar los archivos de la víctima y exigir un rescate por la clave de descifrado. La extorsión doble, popularizada por grupos como Maze a partir de 2019, añadió a la amenaza del cifrado la de filtrar públicamente los datos exfiltrados si no se pagaba el rescate, neutralizando así la efectividad de los respaldos como única defensa. La extorsión triple, predominante en los últimos años, incorpora un tercer vector: el atacante contacta directamente a los clientes, proveedores o socios de la víctima para presionar mediante la amenaza de filtración de sus datos personales (Sophos, 2024).

Adicionalmente, el modelo de negocio del ransomware ha mutado hacia el esquema «Ransomware-as-a-Service» (RaaS), en el que operadores especializados desarrollan y mantienen la plataforma, mientras que afiliados independientes la utilizan para ejecutar ataques a cambio de un porcentaje del rescate obtenido. Esta industrialización ha multiplicado la frecuencia de los ataques y ha reducido drásticamente la barrera técnica de entrada para nuevos actores maliciosos.

1.10.2. Ataques a la cadena de suministro

Los ataques a la cadena de suministro explotan la confianza implícita que las organizaciones depositan en sus proveedores de software. En lugar de atacar directamente al objetivo final —usualmente bien defendido—, el adversario compromete a un proveedor de confianza e inyecta código malicioso en sus productos o actualizaciones. Cuando los clientes finales instalan estas actualizaciones por canales legítimos, el malware se distribuye masivamente, eludiendo las defensas perimetrales basadas en la confianza en el origen.

Más allá del paradigmático caso de SolarWinds, la amenaza incluye episodios como NotPetya (2017), que utilizó la infraestructura de actualización del software contable ucraniano M.E.Doc para causar daños globales estimados en 10,000 millones de dólares (Greenberg, 2018), y el incidente de la biblioteca XZ Utils descubierto en 2024, en el que un atacante logró introducir, mediante meses de contribuciones aparentemente legítimas al proyecto de código abierto, una puerta trasera que estuvo a punto de ser distribuida en distribuciones mayoritarias de Linux (Freund, 2024).

1.11. Impacto multidimensional: consecuencias reales de una brecha

Las consecuencias de una brecha de seguridad trascienden ampliamente el plano técnico inmediato. Cuatro dimensiones permiten organizar el análisis de su impacto sobre la organización.

Dimensión financiera. El costo promedio global por brecha alcanzó 4.88 millones de dólares en 2024 (IBM Security, 2024). Esta cifra incorpora el pago de rescates, las multas regulatorias, los costos de investigación forense, la pérdida de clientes, la caída del valor accionario y el costo de la respuesta y remediación posterior al incidente.

Dimensión reputacional. La confianza institucional, que se construye a lo largo de años o décadas, puede destruirse en minutos. Estudios sectoriales reportan que entre 25 % y 40 % de los clientes abandonan una empresa tras conocer que ha sufrido una brecha grave de datos personales (Centrify, 2019). El daño reputacional suele exceder, en el largo plazo, el costo directo del incidente.

Dimensión operativa. Los incidentes digitales pueden ocasionar la paralización total de operaciones físicas. El caso de Colonial Pipeline en mayo de 2021, en el que un ataque de ransomware obligó a detener el principal oleoducto del este de los Estados Unidos, generó desabastecimiento de combustible en múltiples estados y constituye un ejemplo emblemático de cómo el ciberespacio impacta la economía física (CISA, 2021).

Dimensión legal y regulatoria. Las consecuencias jurídicas son cada vez más severas. En el Perú, la Ley N.º 29733 de Protección de Datos Personales establece sanciones que pueden alcanzar las 100 UIT por infracciones muy graves (Congreso de la República del Perú, 2011). A escala internacional, el Reglamento General de Protección de Datos (GDPR) de la Unión Europea contempla multas de hasta el 4 % de la facturación global anual de la empresa. La seguridad ha dejado, así, de ser una opción para constituirse en una obligación legal.

1.12. La arquitectura de solución: el ecosistema Personas-Procesos-Tecnología

Frente a un panorama de amenazas tan complejo, la defensa eficaz exige abandonar la ilusión de la solución única. El modelo Personas-Procesos-Tecnología (PPT), de amplia adopción en la literatura de gestión de seguridad, propone que la protección sostenible requiere la articulación equilibrada de tres componentes interdependientes (Schneier, 2003).

Personas. Reportes consistentes indican que aproximadamente el 82 % de las brechas analizadas involucran de algún modo el factor humano —errores, configuraciones incorrectas, ingeniería social exitosa o uso indebido de privilegios (Verizon, 2024). Ninguna tecnología detiene por sí sola un ataque de phishing exitoso si el usuario hace clic en el enlace y entrega sus credenciales. La cultura de seguridad organizacional, la formación continua y la sensibilización son, por tanto, componentes irremplazables.

Procesos. Las políticas, procedimientos y planes formalizados —en particular los planes de respuesta a incidentes, los procedimientos de gestión de cambios y los esquemas de continuidad del negocio establecidos en estándares como la ISO/IEC 27001:2022— proporcionan el marco que transforma decisiones ad hoc en respuestas previsibles y auditables (ISO/IEC, 2022). En ausencia de procesos documentados, la respuesta a un incidente tiende al caos.

Tecnología. Firewalls de nueva generación, sistemas SIEM, plataformas XDR (Extended Detection and Response), soluciones de autenticación multifactor y mecanismos de cifrado son herramientas esenciales pero insuficientes por sí solas. La inversión millonaria en tecnología sin la educación de las personas y sin la definición de procesos equivale, en palabras frecuentemente citadas, a construir una fortaleza con las puertas abiertas.

El equilibrio entre estos tres componentes constituye la única defensa real ante amenazas de la complejidad descrita en las secciones anteriores.

1.13. Reflexión final: la seguridad como proceso

La seguridad no es un producto, es un proceso.

(Schneier, 2000, p. xii)

La sentencia de Bruce Schneier sintetiza con precisión la idea central de este capítulo. La seguridad total es inalcanzable: ningún sistema —ni hoy ni en el futuro previsible— estará completamente libre de riesgo. Lo que sí está al alcance de las organizaciones es construir capacidades sostenibles para gestionar el riesgo de manera informada, equilibrando la inversión en personas, procesos y tecnología; midiendo continuamente la postura de seguridad; ajustando los controles a la evolución del panorama de amenazas; y, sobre todo, asumiendo que la seguridad es una práctica cotidiana, no un proyecto con fecha de cierre.

Los capítulos subsiguientes desarrollarán las técnicas y metodologías necesarias para llevar este marco conceptual a la práctica: la gestión de riesgos como disciplina formal, los marcos normativos de referencia —en particular ISO/IEC 27001:2022 y el NIST Cybersecurity Framework 2.0—, las arquitecturas Zero Trust, las prácticas DevSecOps, la integración de la inteligencia artificial en la defensa y la transición hacia la criptografía post-cuántica. La travesía empieza aquí, con la convicción de que comprender los fundamentos es la condición indispensable para construir sobre ellos.

Referencias bibliográficas

- Ackoff, R. L. (1989). From data to wisdom. *Journal of Applied Systems Analysis*, 16, 3–9.
- Centrify. (2019). The impact of data breaches on reputation and share value: A study of U.S. marketers, IT practitioners and consumers. Ponemon Institute.
- Chen, H., & Magramo, K. (2024, 4 de febrero). Finance worker pays out \$25 million after video call with deepfake ‘chief financial officer’. CNN. <https://www.cnn.com/2024/02/04/asia/deepfake-cfo-scam-hong-kong-intl-hnk>
- CISA — Cybersecurity and Infrastructure Security Agency. (2021). Joint cybersecurity advisory: DarkSide ransomware — Best practices for preventing business disruption from ransomware attacks (AA21-131A). U.S. Department of Homeland Security. <https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-131a>
- Congreso de la República del Perú. (2011). Ley N.º 29733 — Ley de Protección de Datos Personales. Diario Oficial El Peruano.
- Cybersecurity Ventures. (2025). 2025 Official Cybercrime Report. <https://cybersecurityventures.com/official-cybercrime-report-2025/>
- Freund, A. (2024, 29 de marzo). xz/liblzma: Backdoor in upstream xz/liblzma leading to ssh server compromise [Lista de correo openwall-security]. <https://www.openwall.com/lists/oss-security/2024/03/29/4>
- Goldblum, M., Tsipras, D., Xie, C., Chen, X., Schwarzschild, A., Song, D., Madry, A., Li, B., & Goldstein, T. (2023). Dataset security for machine learning: Data poisoning, backdoor attacks, and defenses. *IEEE Transactions on Pattern Analysis and Machine Intelligence*, 45(2), 1563–1580. <https://doi.org/10.1109/TPAMI.2022.3162397>
- Greenberg, A. (2018, 22 de agosto). The untold story of NotPetya, the most devastating cyberattack in history. *Wired*. <https://www.wired.com/story/notpetya-cyberattack-ukraine-russia-code-crashed-the-world/>
- IBM Security. (2024). Cost of a data breach report 2024. IBM Corporation. <https://www.ibm.com/reports/data-breach>
- ISO/IEC. (2018). ISO/IEC 27000:2018 — Information technology — Security techniques — Information security management systems — Overview and vocabulary. International Organization for Standardization.
- ISO/IEC. (2022). ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements. International Organization for Standardization.

- Kindervag, J. (2010). No more chewy centers: Introducing the zero trust model of information security. Forrester Research.
- Mandiant. (2013). APT1: Exposing one of China's cyber espionage units. Mandiant Intelligence Center Report.
- Mohurle, S., & Patil, M. (2017). A brief study of WannaCry threat: Ransomware attack 2017. *International Journal of Advanced Research in Computer Science*, 8(5), 1938–1940.
- Morgan, S. (2020, 13 de noviembre). Cybercrime to cost the world \$10.5 trillion annually by 2025. *Cybercrime Magazine*. <https://cybersecurityventures.com/cybercrime-damage-costs-10-trillion-by-2025/>
- NIST — National Institute of Standards and Technology. (2020). NIST Special Publication 800-63B — Digital identity guidelines: Authentication and lifecycle management. U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-63b>
- NIST — National Institute of Standards and Technology. (2024). Post-quantum cryptography standardization: FIPS 203, FIPS 204 and FIPS 205. U.S. Department of Commerce. <https://csrc.nist.gov/projects/post-quantum-cryptography>
- Rescorla, E. (2018). The Transport Layer Security (TLS) Protocol version 1.3 (RFC 8446). Internet Engineering Task Force. <https://doi.org/10.17487/RFC8446>
- Rowley, J. (2007). The wisdom hierarchy: Representations of the DIKW hierarchy. *Journal of Information Science*, 33(2), 163–180. <https://doi.org/10.1177/0165551506070706>
- Schneier, B. (2000). *Secrets and lies: Digital security in a networked world*. John Wiley & Sons.
- Schneier, B. (2003). *Beyond fear: Thinking sensibly about security in an uncertain world*. Copernicus Books.
- Sophos. (2024). *The state of ransomware 2024*. Sophos Group.
- Spafford, E. H. (1989). *The internet worm program: An analysis* (Technical Report CSD-TR-823). Purdue University.
- U.S. GAO — Government Accountability Office. (2018). *Data protection: Actions taken by Equifax and federal agencies in response to the 2017 breach* (GAO-18-559). <https://www.gao.gov/products/gao-18-559>
- Verizon. (2024). *2024 Data Breach Investigations Report (DBIR)*. Verizon Business. <https://www.verizon.com/business/resources/reports/dbir/>
- von Solms, R., & van Niekerk, J. (2013). From information security to cyber security. *Computers & Security*, 38, 97–102. <https://doi.org/10.1016/j.cose.2013.04.004>

WEF — World Economic Forum. (2024). Strategic cybersecurity talent framework: Insight report. World Economic Forum. <https://www.weforum.org/publications/strategic-cybersecurity-talent-framework/>